Плейбук реагирования на инцидент: [Тип инцидента]

1. Обнаружение и первичная классификация

Сигналы к реагированию:

- Алерт IDS/IPS о сканировании портов с внешнего IP (Snort: SYN-скан множества портов за короткое время)
- Подозрительные HTTP-запросы к веб-серверу с параметрами cmd=, exec=, command=, shell= в URL
- Алерт DLP о передаче крупных архивов на внешние адреса через SMTP или HTTPS
- Алерт Sysmon: доступ к процессу lsass.exe (Event ID 10) или запуск mimikatz.exe (Event ID 1)
- Алерт Windows Security: запрос прав DS-Replication-Get-Changes-All (Event ID 4662) от не-DC учётки
- Алерт Windows Security: очистка журнала безопасности (Event ID 1102)
- Аномальный исходящий трафик в нерабочее время от внутреннего сервера

Действия:

1. Зафиксировать время, источник сигнала, затронутые хосты и учётные записи. Открыть кейс в TheHive.
2. Провести первичную триаж-оценку: определить, истинное это срабатывание или ложное. Проверить контекст - плановые работы, известные активности, тестовые сценарии.
3. Присвоить уровень критичности (Low / Medium / High / Critical) по матрице: критичность актива × уровень привилегий × объём потенциальной утечки.
4. Собрать первичные IoC: IP-адреса, домены, хеши файлов, имена процессов, учётные записи.
5. Уведомить дежурного L2 и руководителя ИБ, если инцидент классифицирован как High или Critical.
6. Активировать плейбук, зафиксировать время старта реагирования.

2. Сдерживание

Немедленные действия:

1. **Изоляция скомпрометированных систем:**
   - Отключить сетевой доступ у затронутых хостов (карантинный VLAN, блокировка на коммутаторе, EDR-изоляция).
   - Не выключать питание и не перезагружать системы - это уничтожит данные в оперативной памяти.
   - Зафиксировать время изоляции и состояние систем до изменений.

2. **Блокировка известных IoC на периметре сети:**

- Заблокировать на межсетевом экране все внешние IP-адреса и домены из IoC (входящие и исходящие).
- Обновить правила DNS-фильтрации, прокси, DLP.
- Запретить исходящие соединения с затронутых хостов к внешним адресам (кроме адреса сервера сбора логов).
- Включить логирование заблокированного трафика для отслеживания повторных попыток.

3. **Управление учётными записями:**
   - Заблокировать скомпрометированные учётки.
   - Отозвать активные сессии, токены, SSH-ключи, API-ключи, связанные с этими учётками.
   - Сбросить пароли затронутых учёток (после сохранения доказательств).
   - Для критичных системных учёток (например, krbtgt в AD) - не отключать, а запланировать двойную смену пароля.

Проверки:

1. Убедиться, что все IoC заблокированы (проверка правил firewall, DNS, прокси).
2. Проверить изоляцию хостов с другого узла (ping, nc, nmap).
3. Убедиться, что скомпрометированные учётки не могут аутентифицироваться.
4. Проверить отсутствие новых исходящих соединений от изолированных хостов к внешним адресам.

3. Расследование

Сбор доказательств:

1. **Linux-системы:**
   - Логи Auditd (ausearch, aureport) за период инцидента.
   - Системные логи (/var/log/syslog, /var/log/auth.log), journalctl.
   - Логи приложений (Nginx, Apache, БД) - access и error.
   - Дампы каталогов /tmp, /var/spool/cron, /etc/systemd/system, домашние каталоги пользователей.
   - Список процессов, сетевых соединений, открытых файлов на момент изоляции.
   - Снимок диска или критичных директорий для форензики.
2. **Windows-системы:**
   - Логи Windows Security (4624, 4625, 4672, 4648, 4662, 4688, 1102, 7045).
   - Логи Sysmon (Event ID 1, 3, 10, 11, 22).
   - Дампы памяти подозрительных процессов (по возможности — lsass.exe).
   - Содержимое C:\Windows\Temp, C:\Users\Public, C:\ProgramData.
   - Список задач планировщика, служб, ключей автозапуска в реестре.
   - Артефакты браузеров, PowerShell history.
3. **Сетевые артефакты:**
   - PCAP с сенсоров IDS/IPS за период инцидента.

- Логи DLP: передача файлов, объёмы, получатели, статусы.
- Логи межсетевого экрана и прокси: соединения, объёмы трафика.
- DNS-логи: запросы к подозрительным доменам.

Анализ:

1. **Определение вектора атаки:**
   - Восстановить, как атакующий получил первоначальный доступ: фишинг, эксплуатация уязвимости, слабый пароль, компрометация подрядчика.
   - Проверить соответствующие источники: почтовые логи, веб-логи, VPN-логи, логи аутентификации.
2. **Идентификация вредоносного ПО:**
   - Найти все подозрительные файлы: скрипты, бинарники, веб-шеллы, модули.
   - Посчитать хеши MD5/SHA256, сверить с базами (VirusTotal, Kaspersky OpenTIP, URLhaus).
   - Проанализировать поведение: сетевые соединения, создаваемые файлы, изменения реестра.
3. **Анализ повышения привилегий:**
   - Проверить логи на использование sudo, эксплойтов ядра, загрузку модулей, изменение прав.
   - Установить, каким образом атакующий получил привилегии (или не получил).
4. **Исследование кражи учётных данных:**
   - Найти обращения к хранилищам паролей (/etc/shadow, LSASS, браузерные хранилища).
   - Проверить использование инструментов типа mimikatz, gsecdump, LaZagne.
   - Определить перечень скомпрометированных учёток.
5. **Анализ латерального движения:**
   - Восстановить маршрут атакующего по внутренней сети (SMB, RDP, SSH, WMI, PsExec).
   - Проверить события аутентификации с нетипичных источников.
   - Определить, какие ещё системы могли быть затронуты.
6. **Исследование эксфильтрации данных:**
   - Сопоставить события DLP, PCAP, прокси, DNS.
   - Оценить объём и состав потенциально украденных данных.
   - Определить каналы утечки (SMTP, HTTPS, DNS-tunnel, FTP).
7. **Составление хронологии атаки:**
   - Свести все события в единый таймлайн с точным временем.
   - Разметить каждое событие по MITRE ATT&CK.
   - Указать источник данных для каждого события.
   - Проверить таймлайн на логические разрывы.

4. Искоренение угрозы

Действия:

1. **Общие действия:**
   - Отозвать все потенциально скомпрометированные секреты: API-ключи, токены, сертификаты, SSH-ключи.
   - Проверить систему на новые учётные записи, изменения в группах, изменённые права.
   - Проверить задачи планировщика, службы, автозапуск.
   - Проверить cron, systemd, ~/.ssh/authorized_keys на Linux-хостах.
2. **Linux-системы:**
   - Удалить вредоносные артефакты: веб-шеллы, эксплойты, скрипты, модули ядра.
   - Восстановить изменённые конфигурационные файлы.
   - Обновить ПО и ОС, устранить уязвимости.
   - При необходимости - переустановить систему с нуля.
3. **Windows-системы:**
   - Удалить вредоносные файлы, задачи планировщика, ключи реестра.
   - Восстановить изменённые системные файлы.
   - Установить актуальные патчи.
   - При подозрении на глубокую компрометацию - переустановить ОС.
4. **Учётные данные:**
   - Сменить пароли всех привилегированных учёток домена.
   - Для krbtgt в AD - двойная смена с интервалом (иначе Golden Ticket сохранит силу).
   - Обязать всех сотрудников сменить пароли.
   - Внедрить MFA для критичных сервисов.

5. Восстановление

Действия:

1. **Для критичных систем:**
   - Восстановить из чистой резервной копии, созданной до инцидента.
   - Проверить целостность данных и настроек.
   - Убедиться в отсутствии IoC на восстановленной системе.
2. **Linux-системы:**
   - Переустановить ОС или восстановить из чистого снапшота.
   - Развернуть приложения заново, применить актуальные обновления.
   - Настроить усиленный мониторинг (Auditd, filebeat → SIEM).
3. **Windows-системы:**
   - Переустановить ОС или восстановить из чистой копии.
   - Развернуть роли заново, включить Sysmon и расширенный аудит.
   - Применить все патчи, настроить EDR.
4. **Проверка восстановления:**

- Сканирование на IoC по всему перечню.
- Проверка задач планировщика, служб, автозапуска.
- Мониторинг сетевых соединений в течение 72 часов.
- Проверка работоспособности ключевых сервисов.

5. **Постепенное возвращение к работе:**
   - Возвращать системы в продуктивную сеть по одной, от менее критичных к критичным.
   - Усилить мониторинг на первые 7–14 дней.
   - Провести внеплановый аудит прав доступа.
   - Убедиться, что пользователи работают штатно.

6. Извлечённые уроки

Действия:

1. **Анализ инцидента:**
   - Провести разбор со всей командой SOC и IT в течение 2 недель после закрытия.
   - Зафиксировать, что сработало, что нет.
   - Определить пробелы в мониторинге и реагировании.
   - Составить план устранения пробелов с ответственными и сроками.
2. **Улучшение превентивных мер:**
   - Провести аудит и обновление систем защиты.
   - Внедрить сетевую сегментацию и принцип наименьших привилегий.
   - Обновить политики паролей, MFA, доступа.
   - Провести аудит уязвимостей и пентест.
3. **Улучшение мер обнаружения:**
   - Расширить конфигурацию мониторинга (Sysmon, Auditd, EDR).
   - Разработать и внедрить корреляционные правила под выявленный тип атаки.
   - Настроить обязательный сбор логов со всех узлов инфраструктуры.
   - Внедрить автоматизированные проверки IoC в SIEM.
4. **Обучение персонала:**
   - Провести учения по сценарию, аналогичному случившемуся.
   - Обучить SOC-команду новым правилам и процедурам.
   - Провести инструктаж для IT-отдела.
   - Регулярные курсы по фишингу и социальной инженерии для сотрудников.

7. Коммуникации

Внутренние:

1. **Поэтапные уведомления руководства:**
   - Немедленно - краткое резюме (что, где, какие действия).
   - В течение 4 часов - уточнённые данные (затронутые системы, объём утечки).

- Ежедневно - статус расследования и восстановления.
- По завершении - финальный отчёт с выводами и рекомендациями.

2. **Коммуникация с IT-отделом:**
   - Немедленное оповещение и инструкции по изоляции.
   - Регулярные статусы по восстановлению.
   - Инструкции по усилению мониторинга.
   - Разбор инцидента и рекомендации.
3. **Информирование сотрудников:**
   - Уведомление о временной недоступности сервисов.
   - Инструкции по смене пароля и признакам фишинга.
   - Периодические напоминания о правилах безопасности.
   - Итоговое сообщение после восстановления.

Внешние (при необходимости):

1. **Уведомление регуляторов:**
   - Определить необходимость уведомления по закону.
   - Подготовить форму уведомления.
   - Направить в установленный срок.
   - Сохранить копии для аудита.
2. **Взаимодействие с правоохранительными органами:**
   - Консультация с юристами.
   - Подготовка материалов.
   - Подача заявления и поддержание контакта.
3. **Коммуникация с клиентами (если применимо):**
   - Уведомление при утечке клиентских данных.
   - Индивидуальные или общие уведомления.
   - Рекомендации по защите данных.

8. Критерии эскалации

Эскалировать инцидент, если:

- Затронуты критичные узлы: контроллер домена, БД, платёжные системы, системы с ПДн.
- Зафиксирована утечка конфиденциальных данных или персональной информации.
- Атакующий получил привилегии администратора домена или уровень SYSTEM/root.
- Обнаружены признаки APT: длительное присутствие, скрытые механизмы персистентности, использование zero-day.
- Инцидент распространяется на новые системы, сдерживание не удаётся.
- Время реакции превышает SLA.
- Инцидент привлекает внимание регуляторов или руководства.

9. Приложения

Приложение A: Технические индикаторы компрометации (IoC)

IP-адреса:

- [Внешние IP атакующего]
- [IP C2-серверов]
- [IP получателей утечки]

Доменные имена:

- [Вредоносные домены]
- [Домены доставки полезной нагрузки]
- [C2-домены]

Хеши файлов:

- [MD5/SHA256 вредоносных файлов]

Файлы и пути:

- [Пути к артефактам на Linux]
- [Пути к артефактам на Windows]

Приложение B: Поисковые запросы для расследования

Первоначальный доступ (веб-приложение):

url.original:*<подозрительный параметр>* and http.response.status_code:200

Выполнение команд (Linux):

audit.key:("<ключ1>" or "<ключ2>") and process.name:*

Подозрительные процессы (Windows):

event.code:1 and process.name:("<подозрительный процесс>")

Доступ к чувствительным процессам:

event.code:10 and winlog.event_data.TargetImage:*<процесс>.exe

Подозрительная аутентификация:

event.code:4624 and winlog.event_data.LogonType:(3 or 10) and source.ip:*

Изменение критичных файлов:

event.dataset:"fim" and file.path:*<критичный путь>*

Эксфильтрация через SMTP/HTTPS:

event.dataset:"dlp" and (network.protocol:"smtp" or network.protocol:"https") and file.size:>5000000

Приложение С: Шаблоны уведомлений

Шаблон первичного уведомления руководства
Уважаемый [Имя],

Сообщаю о выявлении киберинцидента уровня [уровень]. Затронуты [список систем]. Проводится изоляция и расследование. Активность атакующего [локализована/в процессе локализации].

Подтверждённые факты: [2-3 ключевых факта]. Потенциальный объём утечки: [X]. Пострадавших сервисов: [список].

Следующее обновление - через [X часов]. Контактное лицо: [Имя, телефон].

Шаблон уведомления для IT-персонала
Коллеги,

Зафиксирован инцидент ИБ. По системам [список] подтверждена компрометация. Действия, которые необходимо выполнить незамедлительно:

Изолировать указанные хосты от сети.

Сменить пароли учётных записей [список].

Проверить наличие артефактов по списку IoC: [ссылка].

Включить расширенный мониторинг.

Все действия фиксировать в тикете [номер]. Вопросы - [контакт].

Шаблон уведомления для сотрудников
Уважаемые коллеги,

В связи с техническими работами возможны временные перебои в работе [список сервисов]. Дополнительно просим вас:

Сменить пароль при следующем входе.

Не открывать подозрительные вложения и ссылки.

Обо всех подозрительных активностях сообщать в ИБ: [контакт].

Приносим извинения за неудобства.

Шаблон уведомления регуляторов (если требуется)
В [наименование регулятора], от [наименование организации].

Уведомление об инциденте информационной безопасности.

Дата инцидента: [дата]. Дата обнаружения: [дата]. Дата уведомления: [дата].

Описание: [краткое описание]. Категория затронутых данных: [персональные/финансовые/иные]. Количество затронутых субъектов: [оценка].

Принятые меры: [список].

Контактное лицо: [Имя, должность, телефон, email].

Плейбук подготовлил: SOC-аналитик Егоров Н.А

Дата: 3 октября 2026